

Hobbeast — Üzleti kérés összefoglaló

Verzió: 1.65.0 Dátum: 2026-09-05

A 139 anon-hívható függvény átvizsgálása — két valódi lyukkal

A cél a támadási felület csökkentése volt. Menet közben ****három konkrét, élesben kihasználható sebezhetőség**** került elő. Egyiket sem elmélet alapján állítom: mindegyiket lefuttattam az éles adatbázison, majd visszagörgettem.

1. A webhook-titok bárkinek kiadta magát

A `get_email_webhook_secret()` SECURITY DEFINER volt, ****mindenféle belső őrről nélkül****, és a Supabase alapértelmezett jogosztása miatt az anon hívhatta. Vagyis a nyilvános anon kulccsal bárki lekérdezhetette az e-mail-beolvasó webhook-titkát. Anonként szimulálva 64 karakteres titok jött vissza.

A 20260828011000 migráció a ***szándékot*** le is írta — „service role; the webhook reads this to verify callers” —, csak épp soha nem kényszerítette ki.

Két független zár került rá, mert külön-külön mindkettő már megbukott nálunk: egy törzsbeli `service_role`-ellenőrzés (így egy jövőbeli újra-grant sem nyitja ki), és a visszavonás, ami néven nevezi az anon-t — a pusztá REVOKE ... FROM PUBLIC a Supabase közvetlen szerep-grantjai ellen hatástalan.

2. Háromértékű logika: az őrről, ami épp az ellenkezőjét csinálta

Kijelentkezett hívónál `auth.uid()` NULL, így `p_user_id <> NULL → NULL`, `NULL AND true → NULL`, és az IF NULL THEN ág nem hajtodik végre. Az őrről úgy olvasódik, mintha tiltana; pontosan az ellenkezőjét teszi.

Élesben bizonyítva, majd visszagörgetve: `remove_org_member` — anonként egy vadidegen szervezet tagja `active`-ból `removed` állapotba került. `assign_event_organization` — anonként más felhasználó eseménye levált a szervezetéről. A `p_org_id => NULL` ráadásul az `ORG_EDITOR_REQUIRED` ágot is átugorja, mert az IF `p_org_id IS NOT NULL AND ...` alatt van. `cancel_ticket_order` — nem anon-hívható, de ugyanaz az alak: egy NULL `buyer_user_id`-jú rendelésnél bármely bejelentkezett hívónak elmaradna az ellenőrzés. A másik kettővel együtt javítva, nem hagyva ismert csapdaként.

A javítás az IS DISTINCT FROM (ami soha nem NULL) plusz egy kimondott elutasítás, ha nincs bejelentkezett felhasználó. Jogos hívóra a viselkedés változatlan: nem-null operandusokra az IS DISTINCT FROM azonos a `<>`-vel.

3. A felület szűkítése: 139 → 37

Minden nevet bizonyíték alapján soroltam be, nem a neve alapján: kereszthivatkozva az `src/` és a `supabase/functions/` összes `.rpc('...')` hívásával, élesben anonként végigpróbálva (tilt / átmegy / hibázik), és megnézve, szerepel-e RLS-policy vagy nézet definíciójában.

Ez a kereszthivatkozás meg is fogta magát: a `reconcile_virtual_hub_member` karbantartó jobbnak ***néz ki***, de az `Onboarding.tsx` és a `Profile.tsx` hívja a bejelentkezett felhasználóra — így az anon-only rétegbe került, nem a `service_role`-ba. Név alapján rossz helyre tettem volna.

Amihez szándékosan nem nyúltam: az RLS-policy és nézet-segédék (`has_role`, `is_organization_member`, ...) — ezeket a kijelentkezett látogató policy-ellenőrzése hívja, a visszavonásuk azonnal eltörné a publikus olvasást; a felfedező felület (`list_discoverable_events_safe`, `map_markers`, `event_safe_payload`, ...), ami épp az anonim látogatóknak felel; és a trigger-függvények, mert a trigger visszatérési típusú függvény PostgreSQL-en át egyáltalán nem hívható, tehát nem is része az elérhető felületnek.

Regresszió-ellenőrzés

Anonként, a szigorítás után: a publikus eseményoldal 24 eseményt és 50 várost ad vissza, az első kártya címe „Den Römern auf der Spur” — épp az egyik ma még nullát adó forrásból. A `public_profile_cards` nézet 934 profilból pontosan a 933 publikusat mutatja, a privát egy nem szivárog, és mind a 934 rejtett érdeklődési köre üresen jön. A jogos útvonalak élnek: az esemény készítője továbbra is leválasztja a saját eseményét, a tag továbbra is kilép magától.

A két megmaradó advisor-ERROR (public_profile_cards, circle_health_dashboard) mintázat-figyelmeztetés, nem lyuk: mindkét nézet a saját WHERE-jében szűr, és épp azért definer, hogy az anon a profiles-t közvetlen tábla-jog nélkül olvashassa. Invokerre váltásuk nem szigorítás lenne, hanem a termék eltörése.

Ez az összefoglaló 2026-09-05-én készült visszamenőleg, a CHANGELOG.md megfelelő bejegyzéséből származtatva, mert ehhez a verzióhoz eredetileg nem készült versioning-artefaktum. A tartalma a changeloból ellenőrizhető; nem a kiadás napján kelt dokumentum.